Astro Security Audit Report

Security review of 16 migrated websites

Developer handoff - August 6, 2026 (UTC)

ABSTRACT

This report documents a read-only security review of the current Astro deployments, their source configuration, server routes, content handling, dependency state, deployment secrets, and observable production HTTP headers. The review found several urgent issues unrelated to Astro's core release: exposed certificate-authority private keys, query-string authentication, shared credentials, direct-origin exposure, an uploaded-PHP execution path, and unsanitized CMS HTML. The overall rating is **HIGH RISK** until the Priority 0 items are completed.

1. Executive decision summary

All 16 projects are hybrid Astro applications. Every project declares `output: 'static'` with the Node standalone adapter, but each contains at least one `prerender = false` route. Therefore, none should be operated or described as a fully static site. Dynamic pages and API routes have the security properties of a server application and require patching, monitoring, access control, and origin hardening.

Astro 7.1.6 and @astrojs/node 11.0.3 are current and are not affected by the two Astro advisories supplied for this review. The highest risks are in application and infrastructure code around Astro, not in the installed Astro version itself.

The developer should treat the following as incident-response work, not routine hardening:

1. Rotate the Caddy internal root and intermediate certificate authorities. Their private keys are present in Git-tracked rollback material and match the active CA public keys.
2. Disable the uploaded-PHP save and execution paths, especially Kinza's live PHP runner, until a safer design is deployed.
3. Remove query-string authentication, rotate the affected internal secrets, and assign a unique credential per site and purpose.
4. Block direct public access to every origin. Permit only Cloudflare or move to an authenticated tunnel, then use strict origin certificate validation.
5. Treat all stored CMS HTML as untrusted. Sanitize it, fix search DOM insertion, block SVG uploads, and constrain third-party tag injection.

2. Scope and limitations

The review covered these 16 domains:

- c-uae.com, cbss.ae, connectfm.ae, connectfz.com, connectgroup.co, connecthr.ae, connectresources.ae, and connectresources.sa.
- connectstaff.ae, eormiddleast.com, evolutionmiddleast.com, iberiaeor.com, iberiaworkforce.com, kinzahr.com, royalvisa.ae, and spheavyrental.ae.

The work was read-only. It included source and configuration review for all 16 sites, dependency advisory checks, live HTTPS response-header checks for all domains, and inspection of the active Caddy and systemd configuration available on the current host. The current host runs nine of the sites; platform internals for the other seven could not be verified from this host. No forms were submitted, no credentials were used, and no production data was modified.

Live checks reflect the state observed on August 6, 2026. Cloudflare challenge pages were returned for connecthr.ae and eormiddleast.com, so their application-response headers could not be reliably assessed from the public edge.

3. Priority 0 findings - change immediately

3.1. P0-1: Active certificate-authority private keys are tracked in Git

Impact: Critical. Anyone who has obtained the repository or its history can impersonate an origin protected by this internal CA. Removing only the working-tree files does not invalidate copied keys.

The repository contains Caddy rollback material under:

```
caddy/upgrade-rollback-20260803/.../root.key
caddy/upgrade-rollback-20260803/.../intermediate.key
```

Cryptographic comparison showed that the archived root and intermediate private keys correspond to the active Caddy CA public keys. Archived leaf keys did not match the current leaf certificates, but that does not reduce the CA compromise.

Required response:

[ ] Generate a new root and intermediate CA, then issue new origin certificates.

[ ] Deploy the replacement certificates before revoking trust in the old CA.

[ ] Remove the private keys from the repository and rewrite Git history where feasible.

[ ] Rotate or rebuild any system that may have trusted the compromised CA.

[ ] Store future private keys outside the repository with least-privilege filesystem access.

[ ] Review clone, CI artifact, backup, and access logs to determine exposure scope.

3.2. P0-2: Query-string credentials and shared internal secrets

Impact: Critical credential leakage and broad lateral access. The shared internal authentication helper accepts `?secret=...` in addition to headers or bearer tokens. Kinza also accepts `?key=...`. URLs routinely appear in proxy logs, analytics, browser history, screenshots, support tickets, and referrer data.

Four active sites use the same `INTERNAL_JOB_SECRET`: c-uae.com, connectstaff.ae, eormiddleast.com, and kinzahr.com. A leak on one site therefore grants access to protected functions on the others.

Required response:

[ ] Remove all query-parameter credential support. Accept only an authorization header.

[ ] Rotate the current shared value immediately after the code path is removed.

[ ] Issue unique, scoped credentials per site, environment, and job purpose.

[ ] Redact sensitive headers and legacy query parameters from every log pipeline.

[ ] Add expiry and rotation procedures; prefer signed short-lived requests where possible.

3.3. P0-3: Authenticated upload endpoints can deploy PHP; Kinza executes it

Impact: Critical remote code execution following credential compromise or an authorization flaw. Fourteen full-CMS sites expose authenticated save/upload endpoints capable of writing deployable PHP. Kinza contains `src/pages/enhanced/[...path].ts`, which selects uploaded PHP and starts the PHP interpreter. This makes an otherwise static-content publishing feature an operating system code-execution boundary.

Required response:

[ ] Disable PHP upload/save routes and the Kinza PHP runner immediately.

[ ] Remove PHP execution from the web service account and deployment directory.

[ ] Store user-controlled content in non-executable object storage, outside the web root.

[ ] Permit only a small allowlist of content formats; verify MIME type and file signature.

[ ] Audit historical uploads and access logs before restoring any publishing route.

3.4. P0-4: Direct origin access bypasses Cloudflare controls

Impact: High to critical, depending on Cloudflare WAF and access policies. Direct TLS requests to the documented origin IP, with certificate verification disabled, reached all nine sites hosted on the inspected origin and returned HTTP 200 or 301. Attackers can therefore bypass edge filtering, rate limits, bot controls, and some header policies.

The current Caddy configuration describes Cloudflare **Full** mode rather than **Full (strict)** and relies on Caddy's internal certificates.

Required response:

[ ] At the network layer, allow inbound HTTP/S only from current Cloudflare address ranges.

[ ] Prefer Cloudflare Tunnel or Authenticated Origin Pulls when operationally suitable.

[ ] After replacing the exposed CA, install a valid origin certificate and enable Full (strict).

[ ] Repeat direct-IP tests from an external network; they should time out or be rejected.

3.5. P0-5: Stored and DOM XSS paths in CMS rendering

Impact: High. Fourteen full-CMS applications accept raw `contentHtml`. Modern sites render CMS fields with Astro's `set:html` directive. Legacy sites insert the HTML into complete responses. The CMS save path does not sanitize the input.

Search pages also insert content-derived titles, paths, and excerpts into `innerHTML` without escaping. The so-called GTM sanitizer strips only selected WordPress Rocket attributes and still permits arbitrary script, body, and footer markup. This is not an HTML security sanitizer.

Featured-image upload accepts SVG by filename extension and serves it from a public same-origin path without validating MIME type or file signature. Active SVG content can become a same-origin script vector.

Required response:

[ ] Sanitize stored HTML on ingestion with a versioned allowlist and sanitize again at render time while legacy data is being cleaned.

[ ] Build search results with text nodes or framework escaping, never string-based innerHTML.

[ ] Replace free-form GTM/script injection with validated IDs or a tightly controlled allowlist.

[ ] Reject SVG uploads or process them through a proven sanitizer and isolated media domain.

[ ] Validate extension, declared MIME type, and decoded file signature for every upload.

3.6. P0-6: User text is embedded unescaped in notification email HTML

The notification path produces an HTML body equivalent to `<pre>${text}</pre>` without HTML-escaping the user message. A submitted message can inject markup into administrative email. While email clients restrict scripting, HTML and link injection can still enable convincing phishing and misleading UI.

Escape the five HTML metacharacters before creating HTML email, or send only a plain-text part. Continue to supply both safe text and safe HTML alternatives if rich email is required.

4. Rendering and route inventory

Conclusion: none of the sites is fully static. The counts below are source route files, not total reachable URLs; a single dynamic catch-all can serve many paths.

Domain	SSR pages	API routes
c-uae.com	18	36
cbss.ae	2	8
connectfm.ae	18	36
connectfz.com	21	36
connectgroup.co	10	35
connecthr.ae	14	35
connectresources.ae	15	36

Domain	SSR pages	API routes
connectresources.sa	16	35
connectstaff.ae	16	35
eormiddleast.com	20	36
evolutionmiddleast.com	15	34
iberiaeor.com	22	36
iberiaworkforce.com	1	9
kinzahr.com	17	35
royalvisa.ae	16	36
spheavyrental.ae	13	36

All projects use Astro's static output setting with the Node standalone adapter, but at least one page or endpoint opts into on-demand rendering. Operationally, this means:

- Keep the Node runtime and adapter patched and monitored.
- Apply server-side validation and authorization to every endpoint.
- Set explicit cache behavior for API, personalized, and generated responses.
- Prerender public pages that do not truly require request-time data.

5. Astro security configuration

5.1. Origin checking

`security.checkOrigin` is effective on all 16 sites. It is explicitly true on nine sites: c-uae.com, connectfm.ae, connectfz.com, connecthr.ae, connectresources.ae, eormiddleast.com, iberiaeor.com, iberiaworkforce.com, and spheavyrental.ae. The other seven inherit Astro's true default.

Make it explicit in every configuration so an Astro default change or code review does not obscure the intended policy. Do not treat it as complete CSRF protection: Astro's check applies to on-demand mutating requests with selected form, multipart, or text content types, not every JSON request or custom endpoint authorization flow.

5.2. Allowed domains

All sites configure `security.allowedDomains`. Fifteen permit production HTTP host variants; only connectgroup.co limits production matching to HTTPS. Many configs also include localhost entries. This setting determines which forwarded host values Astro trusts; it is not a general browser-origin allowlist.

Use environment-specific lists. Production should contain only exact HTTPS production hosts that the trusted reverse proxy sets. Keep localhost and preview domains out of the production bundle. The proxy must overwrite, not append to, forwarded host/protocol headers received from the public Internet.

5.3. Content Security Policy

No source configuration enables Astro's `security.csp`. A CSP should primarily be emitted as an HTTP response header at Caddy or Cloudflare so it covers Astro pages, legacy HTML, errors, redirects, and non-Astro responses. Astro's CSP support can add defense in depth for Astro-rendered pages.

Do not deploy a strict enforcing policy blindly: legacy pages contain extensive inline and third-party scripts. Begin with `Content-Security-Policy-Report-Only`, collect violations, remove obsolete dependencies, then enforce a nonce- or hash-based policy. Avoid `'unsafe-eval'` and minimize `'unsafe-inline'`.

6. Content, input, and injection review

6.1. Raw HTML groups

Modern raw-CMS group: c-uae.com, connectfm.ae, connectfz.com, connecthr.ae, connectresources.ae, eormiddleast.com, iberiaeor.com, and spheavyrental.ae. Their SSR catch-all pages load JSON content and render HTML via `set:html`. Their search interfaces also use client-side HTML insertion.

Legacy responder group: connectgroup.co, connectresources.sa, connectstaff.ae, evolutionmiddleast.com, kinzahr.com, and royalvisa.ae. They serve cleaned legacy HTML or construct complete `Response` bodies with

CMS HTML.

Leads-only group: cbss.ae and iberiaworkforce.com. They have a smaller attack surface, although CBSS loads several external scripts and both still run server endpoints.

No active rendered Markdown or MDX content pipeline was found. Markdown references were limited to project notes and README-style material, so Markdown-specific HTML sanitization is not currently the main concern.

6.2. Forms, search parameters, cookies, and API routes

Every site posts forms to its own `/api/contact` route rather than directly from the browser to an external form provider. The server then integrates with Pipedrive and/or SMTP. Positive controls include server-side field checks and length limits, honeypots, a five-per-minute IP limiter, durable lead storage, and idempotency support.

Remaining form risks:

- The 32 KB body check relies on Content-Length, then buffers JSON or form data. Chunked or omitted lengths can bypass the pre-check. Enforce body size at Cloudflare/Caddy and again while streaming or parsing.
- The rate limit is an in-process Map. It resets on restart, does not coordinate across instances, can grow, and trusts the first forwarded IP. Move the control to the edge or a shared store and accept client IP only from a trusted proxy chain.
- Add Turnstile or an equivalent challenge if abuse continues after edge rate limiting.

Client-side attribution cookies are used across the portfolio. They are generally SameSite=Lax and Secure but cannot be HttpOnly because browser scripts read them. No active server authentication cookie flow was found, although some inactive/dead modules remain. Keep attribution cookies non-sensitive, limit lifetime and scope, and obtain the appropriate consent where required.

API surface ranges from 8 to 36 route files per site. Fourteen sites have the full CMS surface; CBSS and Iberia Workforce are primarily leads-only. Perform route-level tests for authorization, content type, maximum body size, schema validation, rate limiting, error disclosure, and cache control after the Priority 0 paths are removed.

6.3. Third-party JavaScript

Legacy pages retain large quantities of WordPress-era JavaScript. Representative source counts were: CBSS 6 external script references with 0 integrity attributes; Connect Group 99 with 51; Connect Staff 235 with 0; Evolution Middle East 84 with 0; and Kinza 158 with 1. Counts include repeated references across pages, but demonstrate a large supply-chain and CSP maintenance surface.

Remove unused plugins and CDNs. Self-host stable assets when licensing permits. For necessary cross-origin static assets, pin versions and use Subresource Integrity with `crossorigin`. Keep analytics/tag-manager access limited and auditable; SRI cannot protect mutable tag-manager payloads, so CSP and vendor governance remain necessary.

7. Dependency and advisory status

7.1. Audit method and results

The workspace uses a pnpm lockfile. `npm audit --json` cannot provide a valid result here because npm requires a package-lock and returned ENOLOCK. The correct lockfile-aware equivalent, `pnpm audit`, was used.

Production dependencies produced 8 findings: 2 high, 5 moderate, and 1 low. All were through Nodemailer 7.0.5. The full dependency graph produced 10 findings: 4 high, 5 moderate, and 1 low, adding Playwright 1.49.0 and fast-uri 3.1.4 issues.

Nodemailer	7.0.5 is installed on 11 sites. Update to at least 7.0.11; preferably standardize on the current 9.0.4 release and retest mail behavior.
Playwright	Update 1.49.0 to at least 1.55.1, preferably the current 1.62.1, and rerun browser tests.
fast-uri	Update the transitive 3.1.4 release to at least 3.1.5 through the @astrojs/check graph.
@astrojs/check	Update the older catalog entry to the current 0.9.10 and regenerate the pnpm lockfile.

Astro 7.1.6 is current; no emergency version change is required.

@astrojs/node 11.0.3 is current; no emergency version change is required.

Five sites already use Nodemailer 9.0.3; eleven still inherit 7.0.5 from the workspace catalog. Update to 9.0.4 consistently, review release notes for behavior changes, and test SMTP, attachments, encoding, and error handling.

7.2. Supplied Astro advisories

CVE-2026-50146 / GHSA-8hv8-536x-4wqp: affected Astro versions before 6.3.3. The installed Astro 7.1.6 is outside the vulnerable range.

CVE-2026-29772 / GHSA-3rmj-9m5h-8fpv: affected @astrojs/node 9.x, with fixes in major version 10 and later. The installed 11.0.3 is outside the vulnerable range.

Keep automated production and full-graph audits in CI. A clean Astro core result does not cover custom CMS routes, PHP execution, proxy configuration, or third-party browser scripts.

8. Hosting headers and caching

Of the 14 publicly reachable application responses that were not Cloudflare challenges, 13 lacked CSP. ConnectFZ returned a policy, but it is weak because script sources permit `'unsafe-inline'`, `'unsafe-eval'`, and broad HTTPS origins; style sources also permit inline and broad HTTPS content.

Thirteen of the 14 accessible application responses had HSTS, nosniff, and a Referrer-Policy. Connectresources.ae lacked HSTS, CSP, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, and framing protection in the observed response. Only ConnectFM and ConnectFZ returned Permissions-Policy. Ten of 14 returned X-Frame-Options.

The active main `/etc/caddy/Caddyfile` exactly matched the repository's `/opt/caddy/Caddyfile.production` and validated successfully. It covered nine sites: Evolution Middle East, CBSS, SP Heavy Rental, Iberia Workforce, Connect Group, EOR Middle East, Connect Staff, C-UAE, and Kinza.

That Caddy policy supplies HSTS with one-year max-age, nosniff, SAMEORIGIN framing, and strict-origin-when-cross-origin referrer behavior. It does not set CSP or Permissions-Policy. Do not add HSTS includeSubDomains or preload until every subdomain is verified HTTPS-only and the organization accepts the long-lived operational commitment.

Recommended response baseline, adjusted for each site's dependencies:

- Content-Security-Policy: begin Report-Only, then enforce default-src 'self'; object-src script, style, font, image, connect, and frame sources.
- Strict-Transport-Security: retain at least max-age=31536000 after HTTPS coverage is verified.
- X-Content-Type-Options: nosniff.
- Referrer-Policy: strict-origin-when-cross-origin, or stricter where analytics permit.
- Permissions-Policy: disable unused camera, microphone, geolocation, payment, USB, and other capabilities; explicitly allow only demonstrated requirements.
- Use CSP frame-ancestors as the primary framing control and retain X-Frame-Options for older clients where compatible.

The current Caddy extension matcher gives any URL ending in CSS, JavaScript, image, or font extensions a one-year immutable cache. This can cache non-versioned files and even error responses. Live `/runtime-gtm.js` was generally no-store on CMS sites, but CBSS and Iberia Workforce returned JavaScript 404s carrying one-year immutable caching.

Restrict immutable caching to Astro's content-hashed `/_astro/` assets or another verified fingerprinted path. Use short revalidation for HTML, `no-store` for APIs, internal/admin routes, and personalized responses, and explicit conservative caching for unfingerprinted runtime files and errors.

9. Secrets, environment variables, and service isolation

Positive findings:

- Actual environment files are ignored and none were found tracked in Git.
- No client-exposed `PUBLIC_` secret was identified; observed public variables were non-secret values such as contact endpoints.
- The nine inspected systemd units run as dedicated users with MemoryMax=256M, NoNewPrivileges, PrivateTmp, ProtectHome, and ProtectSystem=strict.

Items to correct:

- The shared production environment file is mode 0640 root:nogroup. Prefer 0600 root:root when systemd loads it directly, or a dedicated root-owned site group with 0640 when a runtime reader genuinely requires group access.
- SP Heavy Rental has a mode 0644 `.env` containing two populated sensitive values. Restrict access and rotate the values if they have ever been valid outside a local sandbox.
- Remove the four-site shared internal secret described in P0-2.
- Add Astro environment schemas and server-only secret validation so builds and services fail closed when required variables are missing or malformed.
- No tracked GitHub Actions workflows were present, so CI secret scopes, logs, and deployment permissions were not assessable. Review these in the actual deployment platform.

Use separate development, preview, and production credentials. Limit CMS, Pipedrive, SMTP, and deployment tokens to the minimum permission and site. Do not expose secrets in build output, browser bundles, source maps, telemetry, form responses, or exception logs.

10. Remediation plan

10.1. Within 24 hours

[ ] Rotate the Caddy root/intermediate CA, deploy new origin certificates, and remove the old keys from Git history and all artifacts.

[ ] Disable PHP uploads and Kinza’s PHP executor; audit past uploads and requests.

[ ] Remove query-string auth; rotate and split every reused internal credential.

[ ] Firewall origins to Cloudflare or deploy a tunnel; enable strict origin verification.

[ ] Update Nodemailer to a safe supported version across all sites and test mail.

[ ] Add the complete header baseline to connectresources.ae and verify its hosting path.

[ ] Escape user content in notification email HTML.

10.2. Within 7 days

[ ] Sanitize CMS HTML, fix search DOM insertion, constrain GTM/script configuration, and reject or safely isolate SVG uploads.

[ ] Enforce request body and distributed rate limits at Cloudflare/Caddy; sanitize trusted proxy headers.

[ ] Deploy CSP Report-Only and a consistent HSTS, nosniff, referrer, permissions, and framing header baseline on every origin and edge path.

[ ] Restrict immutable caching to fingerprinted assets; ensure APIs, admin routes, errors, and runtime scripts have intentional policies.

[ ] Update Playwright, @astrojs/check, and the fast-uri dependency chain. Regenerate the lockfile and run production and full audits in CI.

10.3. Within 30 days

[ ] Prerender every public page that does not require request-time data, reducing the live server surface.

[ ] Remove obsolete WordPress-era scripts, pin remaining vendors, add SRI where applicable, and enforce CSP after report-only tuning.

[ ] Verify all subdomains before considering HSTS includeSubDomains or preload.

[ ] Automate secret scanning, dependency audits, header tests, CSP reporting, origin-bypass checks, and authorization tests.

[ ] Perform an equivalent platform/configuration review for the seven sites not hosted on the inspected server.

11. Developer verification checklist

The remediation is complete only when evidence supports each control:

[ ] Old CA certificates no longer validate new origin connections; repository and history scans find no private keys.

[ ] Requests with legacy `?secret=` or `?key=` parameters fail, and old secrets cannot authenticate anywhere.

[ ] No application route can create or execute PHP or another server-side executable format.

[ ] Direct public origin connections fail while Cloudflare-to-origin traffic succeeds with strict certificate validation.

[ ] Stored XSS test payloads are rejected or rendered inert in pages, search results, previews, and administrative email.

[ ] SVG/polyglot upload tests are rejected and upload content is not executable on the site origin.

[ ] CSP reporting shows an understood, minimized allowlist; enforced CSP passes normal user journeys without unsafe-eval.

[ ] Every public domain returns the approved header baseline on 200, redirect, 404, and 500 paths.

[ ] Fingerprint assets are immutable; HTML revalidates; APIs/admin/errors are not stored publicly.

[ ] Production and full dependency audits are free of high-severity findings or have a written, time-bounded exception.

[ ] Form tests cover oversized/chunked bodies, malformed content, distributed request bursts, forged forwarding headers, duplicate submissions, and upstream failure behavior.

12. References

1. Astro configuration reference - Security: https://docs.astro.build/en/reference/configuration-reference/#security
2. Astro on-demand rendering: https://docs.astro.build/en/guides/on-demand-rendering/
3. Astro configuration reference - CSP: https://docs.astro.build/en/reference/configuration-reference/#securitycsp
4. Astro set:html directive: https://docs.astro.build/en/reference/directives-reference/#sethtml
5. Astro environment variables: https://docs.astro.build/en/guides/environment-variables/
6. npm audit documentation: https://docs.npmjs.com/cli/v11/commands/npm-audit/
7. Astro XSS advisory, CVE-2026-50146 / GHSA-8hv8-536x-4wqp: https://github.com/withastro/astro/security/advisories/GHSA-8hv8-536x-4wqp
8. Astro Node SSR/server islands advisory, CVE-2026-29772 / GHSA-3rmj-9m5h-8fpv: https://github.com/withastro/astro/security/advisories/GHSA-3rmj-9m5h-8fpv
9. Cloudflare Full (strict) SSL/TLS mode: https://developers.cloudflare.com/ssl/origin-configuration/ssl-modes/full-strict/

End of report.